



Administrative Office
of the United States Courts
Department of Technology Services
Information Technology Security Office

Judiciary Information Security Framework (JISF)

Version: 2.2

Published: August 2011

Last Updated: October 2021



Executive Summary

The Judiciary Information Technology Security Program (Program) promotes the confidentiality, integrity, and availability of information associated with all forms of technology utilized by the judiciary. The Program benefits the judiciary by making information available to enable it to conduct day-to-day operations and to accomplish its mission with security commensurate with identified security risks. To facilitate a consistent approach to managing security risks, the Program developed this [Judiciary Information Security Framework](#)¹ (JISF) and recommends its use across the judiciary. Any judiciary organization may implement this JISF, although the terms “national office” and “court unit” appear more frequently and are a type of “judiciary system.”

Emerging technologies combined with threats from hackers, spies, terrorists, professional criminals, and malicious and accidental internal threats make it paramount to protect information via a sound security framework. By doing so, the judiciary can prioritize and identify its critical assets, the associated threats, and strategies for mitigating risk using a consistent vocabulary and approach. This JISF effectively leverages best security practices to create a recommended controls baseline and supporting methodology to assist court units, national systems, and others within the judiciary with the management of information security risks to judiciary systems.

Rather than simply providing a listing of minimally acceptable controls, this JISF goes further by providing decision-makers with a repeatable process for managing information security risk consistently throughout the entire system life cycle. Adoption of this process will result in the determination of appropriate best-practice controls as well as ensure that the judiciary manages risk effectively. This process is based upon an easy-to-follow JISF that includes the following seven steps:

1. Prepare the judiciary and system.
2. Categorize system and information.
3. Select controls.
4. Implement controls.
5. Assess controls.
6. Authorize system or common controls.
7. Monitor system and controls.

These steps are part of a continuous improvement process built on management, operational and technical aspects of information security. As a result, this JISF is the basis for effectively securing judiciary systems now and in the future.

¹ The initial Judiciary Information Security Framework was unanimously endorsed by the Judicial Conference of the United States - Committee on Information Technology, at its June 2011 meeting.

Version History

Version	Approver	Approved	Description of Changes
1.0	DTS-ITSO	August 2011	Initial version.
1.1	DTS-ITSO	June 2017	- Adjusted for NIST terminology and processes. - Added links and updated references. - Replaced Acronyms appendix with link to the IT Security Acronyms listing. - Converted to new ITSO documentation format.
2.0	DTS-ITSO	August 2019	- Adjusted for NIST SP 800-37 Rev. 2. - Changed "Framework" to "JISF". - Added Prepare Section. - Updated Step 5 Authorize.
2.1	DTS-ITSO	November 2019	- Updated links. - Changed version from 2.0a to 2.1.
2.2	Derek Armstrong	October 2021	- Updated format to current ITSO Template. - Adjusted Prepare Section to be Step 1 and consistent with updated JISF Guide. Then, bumped previous Steps 1-6 to 2-7.

Table of Contents

Executive Summary	ii
1. Making the Case for a JISF	1
1.1 Background	1
1.2 Approach and Implementation	2
2. Security Risk Management Framework in the Judiciary	2
2.1 Step 1: Prepare the Judiciary and System	3
2.2 Step 2: Categorize System and Information	4
2.3 Step 3: Select Controls	4
2.4 Step 4: Implement Controls	5
2.5 Step 5: Assess Controls	6
2.6 Step 6: Authorize System or Common Controls	6
2.7 Step 7: Monitor System and Controls	7
3. Understanding the Judiciary Recommended Controls	8
4. Putting the JISF to Work	9
INFORMATION	9
Appendix A: Judiciary Control Families and Examples	A1

List of Figures and Tables

Figure 1 – Security Risk Management Framework (RMF)	3
Table 1 – Control Identifiers and Families	8
Table A1 – Sample Judiciary Recommended Security Controls	A3

1. Making the Case for a JISF

The Judicial Information Technology Security Program (Program) promotes the confidentiality, integrity, and availability of information associated with all forms of technology utilized by the judiciary. The Program benefits the judiciary by making information available to enable it to conduct day-to-day operations and to accomplish its mission with security commensurate with identified security risks. To facilitate a consistent approach to managing security risks, the Program developed this Judiciary Information Security Framework (JISF) and recommends its use across the judiciary.

Emerging technologies combined with threats, which are increasing in both number and sophistication, make it of paramount importance to protect the judiciary's information via a sound security framework. Human threats may be external (from hackers, spies, terrorists, or professional criminals) or internal (from employees, whether accidental or malicious). Natural threats (floods, earthquakes, electrical storms, etc.) and environmental threats (long-term power failure, pollution, chemicals, etc.) also threaten the judiciary's information. A security framework allows the judiciary to prioritize and identify its critical assets, the associated threats, and strategies for mitigating risk using a consistent vocabulary and approach. This JISF effectively leverages best security practices to create a recommended security controls baseline and supporting methodology to assist court units, national systems, and others within the judiciary with the management of information security risks to judiciary systems.

1.1 Background

Judicial independence is a core value that impacts the way the judiciary operates at multiple levels – from guaranteeing freedom from reprisal for legal decisions to exercising autonomy in governance and management. As a result, court units have historically exercised significant independence, including in the administration and management of systems. The Judicial Conference recognizes that the connectivity of court-unit systems in trusted relationships across national systems requires a common baseline for securing the judiciary's systems, whether nationally or locally owned or managed. This JISF establishes that baseline. The judiciary is not typically bound by Executive or Legislative Branch security requirements; however, those requirements and associated guidelines are benchmarks for many security best practices and, where appropriate and feasible, will continue to be adapted for use in the judiciary environment.²

² The National Institute of Standards and Technology (NIST) has Federal responsibility for establishing guidance for the protection of sensitive, unclassified information. The JISF is modeled on NIST Special Publication (SP) 800-37 Rev. 2, December 2018, *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy* and on NIST SP 800-53 Rev. 4, April 2013, *Security and Privacy Controls for Federal Information Systems and Organizations*.

1.2 Approach and Implementation

This JISF provides a high-level management view of a comprehensive security approach that applies to court units, national systems, and others within the judiciary. It is designed to help the judiciary meet the challenge of creating a security posture that balances risk and mission by providing a cyclical model for information security risk management; a detailed compendium of recommended controls based on best practices; and guidance for executing a repeatable and effective process for safeguarding information and systems. Together, these JISF elements form the basis for effectively securing judiciary systems now and in the future. The [Guide to Implementing the Judiciary Information Security Framework](#) (JISF Guide) provides details on how to implement this JISF.

2. Security Risk Management Framework in the Judiciary

The JISF establishes a seven-step, cyclical, continuous improvement process for managing security consistently throughout the entire system life cycle using the Security Risk Management Framework (RMF, see Figure 1).

- Step 1 **Prepare** to execute the RMF from a judiciary-level (Step 1.1) and a system-level (Step 1.2) perspective by establishing a context and priorities for managing security risk.
- Step 2. **Categorize** the system and the information processed, stored, and transmitted by that system based on the potential impact to the judiciary should the system suffer an incident. The greater the negative impact, the higher the system impact rating.
- Step 3. **Select** baseline controls for the system and tailor³ the controls as needed to mitigate risk based on an organizational assessment of risk and local conditions.
- Step 4. **Implement** the controls and describe how the controls are employed within the system and its environment of operation.
- Step 5. **Assess** the controls to determine if the controls are implemented correctly, operating as intended, and producing the desired outcomes with respect to satisfying the security requirements.
- Step 6. **Authorize** the system or common controls based on a determination that the risk to judiciary operations and assets, individuals, other organizations, and the Nation is acceptable.
- Step 7. **Monitor** the system and associated controls on an ongoing basis to include assessing control effectiveness, documenting changes to the system and environment of operation, conducting risk assessments and impact analyses, and reporting the security posture of the system.

³ Tailoring controls is the process by which a control baseline is modified based on: (i) the application of scoping guidance; (ii) the specification of compensating controls, if needed; and (iii) the specification of organization-defined parameters in the controls via explicit assignment and selection statements.



Figure 1 – Security Risk Management Framework (RMF)

Each step is explained further in the JISF Guide, with the results documented in the [Cyber Security Assessment and Management](#) tool (CSAM), which generates the Security Plan (SP). The SP is a document that provides an overview of the security requirements for a system or program and describes the implementation of controls selected to meet those requirements.

2.1 Step 1: Prepare the Judiciary and System

There are essential tasks at the judiciary level (organization) and the system level (judiciary-unit) to help them execute the RMF.⁴ Executing these tasks links essential risk management processes at the system level to risk management processes at the judiciary level. In addition, it establishes responsibility and accountability for the controls implemented within the judiciary's systems and inherited by those systems.

Example Step 1.1 judiciary-level tasks are:

- IT Services, enterprise architecture, and security/cybersecurity tools and related services are developed to provide uniform security processes to the judiciary and reduce costs.

⁴ Complete lists of the judiciary-level tasks and system-level tasks can be found in the JISF Guide.

- Judiciary-tailored control baselines are established and made available (see JISF Guide Appendix B).
- Common controls that are available for inheritance by judiciary systems are identified, documented, and published.

Example Step 1.2 system-level tasks are:

- System security requirements are defined.
- Plan what IT Services can be leveraged to reduce cost and enhance system security.
- Determine the IT system boundary.

Without adequate risk management preparation at the judiciary level, security activities can become too costly, demand too many skilled security professionals, and produce ineffective solutions. A lack of adequate preparation by the judiciary could result in unnecessary redundancy as well as inefficient, costly, and vulnerable systems, services, and applications.

2.2 Step 2: Categorize System and Information

System security categorization is based on the potential impact to the judiciary should events occur that jeopardize the information or the systems needed to accomplish its mission, protect its assets, fulfill its regulatory responsibilities, maintain its day-to-day functions, and protect individuals. Controls applied to each system should be commensurate with the potential impact of a loss of confidentiality, integrity, or availability.

The security categorization for a system is determined by the security categorization of every information type stored or processed by the system. Each information type is first identified then individually categorized by the impact to its security objectives (confidentiality, integrity, and availability) should there be a breach of security.

Consider the following:

- Confidentiality – How important is it to ensure that information is accessible only to those authorized to have access?
- Integrity – What would be the impact to the judiciary’s mission if the information was inaccurate, incomplete, improperly modified or destroyed?
- Availability – What would be the impact to the judiciary’s mission if required information was not readily available?

2.3 Step 3: Select Controls

The next step is to select, tailor, and supplement the appropriate controls based on the system security category as well as the operating environment, individual circumstances, threat environments, and risk tolerance. There are five tasks for selecting a set of controls, which adequately protect a system:

- Identify the recommended controls based on the system security category.
- Tailor the initial set of recommended controls.
- Supplement the tailored controls.
- Document and approve control tailoring.
- Develop a continuous monitoring strategy.

The resulting set of controls are then found in CSAM. Documentation on tailoring and its approval are loaded into CSAM (as artifacts) to support initial and future assessments.

2.4 Step 4: Implement Controls

Once the control selection process has been completed, the controls should be implemented on the system. Details and status of the control implementation should be documented in the SP/CSAM. Although the implementation details will vary by control, the information should be sufficient to allow all users of the SP/CSAM to understand all pertinent information regarding the control and how the control was implemented on the system. Control implementation consists of four tasks:

- Applicability** - For the judiciary, the default control applicability for each control within the system security category (High, Moderate, or Low) is Applicable. It is up to the IT Security Officer (ISO) to adjust the Applicability for each control based on the system.
- Implementation Status** - There are two types of implementation status: Stated Status and Derived Status. The Stated Status of a control is the expected status entered by the ISO and can be Implemented or Not Implemented. If the control is fully implemented on the system, the ISO entered status should be Implemented. When the status is not implemented, partially in place or planned, then the control implementation status is recorded as Not Implemented.

The Derived Status is the actual tested/verified status results from assessments in Steps 5 and 7, and it can be Implemented or Not Implemented.

- Implementation Statements** - The descriptions of control implementation in the SP/CSAM need to answer how the control objective is met and must communicate the following information to properly document the control implementation.
 - Who is responsible for implementing the control?
 - What is implemented?
 - Where is the control implemented?
 - When was/will the control be implemented?
 - How does the implementation satisfy the control or requirement?
 - What artifacts support the control implementation statement?
- Plan of Action and Milestones (POA&Ms)** - POA&Ms were historically referred to as "Risk Mitigation Plans." While documenting the implementation of the controls, the ISO

will identify Partially in Place and Planned implementations which will not be completed before authorizing the system in Step 6. These incomplete control implementations should be reported by the ISO in the system's POA&M to ensure that they are properly addressed in a timely manner. Because an incomplete control implementation is a risk, it is also a vulnerability to the system until fully implemented. The POA&M describes the measures that are planned to complete control implementation.⁵

2.5 Step 5: Assess Controls

It is important to validate through assessing a system's controls to ensure that they are functioning as expected. It is possible that controls have not been properly implemented or performance expectations are inaccurate. It is also possible that changes to the system design or the operating environment affect control suitability.

Revise the SP/CSAM to reflect derived status of the controls (determined during the assessment). Any control deficiencies which result in an unacceptable level of risk should be remediated (improving the security of the system) or tracked for future remediation with a POA&M.

2.6 Step 6: Authorize System or Common Controls

Prior to any system being used or placed into a production mode or common controls being available for inheritance, an Authorizing Official should be designated within the appropriate management structure to provide written authorization for the deployment. For national systems, the Director of the Administrative Office is the Authorizing Official. For court-unit systems, typically a court-unit executive is the Authorizing Official. Any Authorizing Official may delegate this responsibility. Additionally, production systems should undergo reauthorization on a periodic basis, not to exceed five years for court units, where Steps 1.2 through 6 are executed again. A typical schedule for national systems (such as those operated and used by Department of Technology Services (DTS), Department of Program Services (DPS), and Department of Administrative Services (DAS)) is three years for high priority national systems, five years for moderate priority national systems, seven years for low priority national systems,⁶ or upon significant changes.

This authorization implies that the systems or common controls function as expected and that implemented controls are sufficient and operating as intended to address the system's or common controls security category. The tasks involved in authorization are:

⁵ The purpose of the POA&M is to identify, assess, prioritize, and monitor the progress of corrective efforts for security vulnerabilities. It identifies tasks, required resources to accomplish the elements of the plan, any milestones in meeting the tasks, and scheduled completion dates for the milestones.

⁶ National system priority processes can be found in the [National System Assessment Prioritization Criteria](#).

- The system owner (SO) provides the Authorizing Official the information needed to make a risk-based decision regarding the operation and use of the system, or the provision of common controls that can be inherited by judiciary systems.
- The Authorizing Official reviews the system or common controls information to determine if the operational risk⁷ is acceptable.
- The Authorizing Official authorizes or denies authorization for the system to operate, or the common controls to be available for inheritance.

2.7 Step 7: Monitor System and Controls

Security assessments provide a snapshot of security at a point in time. To ensure that judiciary systems controls remain effective as changes in the system and the operating environment occur requires continuous monitoring. The following processes are recommended to perform this monitoring:

- **Assess Changes.** Determine the security impact of proposed or actual changes to the system and its operating environment. Systems are in a constant state of change due to upgrades to hardware, software, firmware, and modifications to the system's environment, which makes monitoring a necessity. An effective security continuous monitoring program entails a disciplined and structured approach to managing, controlling, and documenting changes to the system. The security impact of a change should be determined by a risk assessment prior to implementing the change and, if needed, additional controls implemented to address the level of risk. The SP/CSAM should be updated to reflect these system changes.
- **Test Regularly.** Continue to monitor or regularly test a selected subset of the controls employed within and inherited by the system. A recommended subset of controls and monitoring/testing frequency are provided in the system-specific continuous monitoring strategy developed in Step 3.
- **Perform IT Security Self-Assessments (Scorecard).** These Scorecards are designed to help the SO by providing a roadmap for improving IT security weaknesses. Completed Scorecards are due on or before December 31 annually. Ensuring a self-assessment is conducted using the Scorecard is the responsibility of the SO and ISO.
- **Document and Track Outstanding Weaknesses and Mitigation Activities.** To ensure that system vulnerabilities are corrected, remediation actions should be conducted and documented. Any system vulnerabilities that are not immediately corrected should be tracked and their status periodically reported to appropriate management, such as the Authorizing Official. This can be done as POA&Ms, tracked through CSAM.

⁷ Operational risk is that portion of overall information security risk that remains after the selected controls are successfully implemented. For example, vulnerabilities that are not remediated prior to deployment (for which no plan for remediation is adopted) contribute to operational risk.

- **Disposal Strategy.** A system and component disposal strategy is developed and implemented as needed until the system life cycle is complete and full disposal is implemented.
- **Update Security Documentation.** The implementation of a monitoring program results in ongoing updates to security documentation, e.g. the SP/CSAM and POA&Ms.
- **Periodically Repeat Steps 1.2-6.** Steps 1.2 through 6 of the judiciary's RMF (see Figure 1) should periodically be performed on the system. This will validate the security category and the controls applied to the system, reassess the effectiveness of those controls, and ensure that reauthorization to continue to operate is appropriately considered.

3. Understanding the Judiciary Recommended Controls

Controls are implemented to reduce risk to an acceptable level. For example, a badge reader on a door may be used to limit access to a restricted area. To assist with security risk management across the judiciary, the JISF's companion document, the JISF Guide, includes a customized set of controls, the Judiciary Recommended Security Controls, which are recommended for selection based upon the system security category. The JISF was originally modeled on the controls identified in NIST SP 800-53 Rev. 3, August 2009, *Recommended Security Controls for Federal Information Systems and Organizations*, then updated using NIST SP 800-53 Rev. 4, April 2013, *Security and Privacy Controls for Federal Information Systems and Organizations*. Judiciary controls have been selected and modified to better address the unique needs of the judiciary. The controls are organized into eighteen families. Table 1 shows the distribution of the families, as well as each family's two-character identifier.

Table 1 – Control Identifiers and Families

Identifier	Family
AC	Access Control
AT	Awareness and Training
AU	Audit and Accountability
CA	Security Assessment and Authorization
CM	Configuration Management
CP	Contingency Planning
IA	Identification and Authentication
IR	Incident Response
MA	Maintenance

Identifier	Family
MP	Media Protection
PE	Physical and Environmental Protection
PL	Planning
PM	Program Management
PS	Personnel Security
RA	Risk Assessment
SA	System and Services Acquisition
SC	System and Communications Protection
SI	System and Information Integrity

Appendix A contains a summary of each control family's functionality. The JISF Guide contains a comprehensive compendium of controls across each of these control families that are recommended for selection based on the system's security category.

4. Putting the JISF to Work

Sections 1 and 2 summarize the judiciary's approach to a comprehensive JISF as a cyclical and repeatable process for managing security consistently throughout the entire system life cycle. Section 3 introduces the Judiciary Recommended Security Controls, which form the basis for a system's protection profile and are the focus of ongoing monitoring activities. While the JISF and compendium of controls have been outlined, more detail is necessary to apply this JISF to existing and future systems in a meaningful way. That additional detail is available in the [JISF Guide](#). Together, this JISF and its companion document provide effective guidance for managing information security risk and for protecting judiciary information and systems.

INFORMATION

The [IT Security Acronyms](#) listing and [Glossary of Judiciary Information Security Framework Terms](#) are available for further clarification.

Questions or comments concerning this document may be directed to the [IT Security Office](#) at (202) 502-2350. Also, JISF/RMF process questions can be sent to ITSO Security Policy and Assessment's [Judiciary ISO Support](#).

Appendix A: Judiciary Control Families and Examples

Judiciary controls are organized into eighteen families. Each family contains controls related to the security functionality of the family. The control families for the judiciary, in summary, are:

- **Access Control (AC):** The judiciary should limit system access to authorized users, processes acting on behalf of authorized users, or devices (including other systems) and to the types of transactions and functions that authorized users are permitted to exercise.
- **Awareness and Training (AT):** The judiciary should: (i) ensure that managers and users of judiciary systems are made aware of the security risks associated with their activities and of the applicable laws, directives, policies, standards, instructions, regulations, or procedures related to the security of judiciary systems; and (ii) ensure that judiciary personnel are adequately trained to carry out their assigned information security-related duties and responsibilities.
- **Audit and Accountability (AU):** The judiciary should: (i) create, protect, and retain system audit records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful, unauthorized, or inappropriate system activity; and (ii) ensure that the actions of individual system users can be uniquely traced to those users so they can be held accountable for their actions.
- **Security Assessment and Authorization (CA):** The judiciary should: (i) periodically assess the controls in judiciary systems to determine if the controls are effective in their application; (ii) develop and implement POA&Ms designed to correct deficiencies and reduce or eliminate vulnerabilities in judiciary systems; (iii) authorize the operation of judiciary systems or common controls, and any associated system connections; and (iv) monitor controls on an ongoing basis to ensure the continued effectiveness of the controls.
- **Configuration Management (CM):** The judiciary should: (i) establish and maintain baseline configurations and inventories of judiciary systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles; and (ii) establish and enforce security configuration settings for information technology products employed in judiciary systems.
- **Contingency Planning (CP):** The judiciary should establish, maintain, and effectively implement plans for emergency response, backup operations, and recovery and reconstitution for judiciary systems to ensure the availability of critical information resources and continuity of operations in emergency situations.

- **Identification and Authentication (IA):** The judiciary should identify system users, processes acting on behalf of users, or devices and authenticate (or verify) the identities of those users, processes, or devices, as a prerequisite to allowing access to judiciary systems.
- **Incident Response (IR):** The judiciary should: (i) establish an operational incident handling capability for judiciary systems that includes adequate preparation, detection, analysis, containment, recovery, and user response activities; and (ii) track, document, and report incidents to appropriate judiciary officials and/or authorities.
- **Maintenance (MA):** The judiciary should: (i) perform periodic and timely maintenance on judiciary systems; and (ii) provide effective controls on the tools, techniques, mechanisms, and personnel used to conduct system maintenance.
- **Media Protection (MP):** The judiciary should: (i) protect system media, both paper and digital; (ii) limit access to information on system media to authorized users; and (iii) sanitize or destroy system media before disposal or release for reuse.
- **Physical and Environmental Protection (PE):** The judiciary should: (i) limit physical access to systems, equipment, and the respective operating environments to authorized individuals; (ii) protect the physical plant and support infrastructure for systems; (iii) provide supporting utilities for systems; (iv) protect systems against environmental hazards; and (v) provide appropriate environmental controls in facilities containing systems.
- **Planning (PL):** The judiciary should develop, document, periodically update, and implement security plans for judiciary systems that describe the controls in place or planned for the systems and the rules of behavior for individuals accessing the systems.
- **Program Management (PM):** The judiciary should develop, document, periodically update, and implement security program management controls to provide a foundation for the judiciary's information security program. Program management controls complement the controls for a system by focusing on the judiciary-wide (or court-unit-wide) information security requirements that are independent of any particular system and are essential for managing information security programs.
- **Personnel Security (PS):** The judiciary should: (i) ensure that individuals occupying positions of responsibility within the judiciary (including third-party service providers) are trustworthy and meet established security criteria for those positions; (ii) ensure that judiciary information and systems are protected during and after personnel actions such as terminations and transfers; and (iii) employ formal sanctions for personnel failing to comply with judiciary security policies and procedures.
- **Risk Assessment (RA):** The judiciary should periodically assess the risk to judiciary operations (including mission, functions, image, or reputation), judiciary assets, and individuals, resulting from the operation of judiciary systems and the associated processing, storage, or transmission of judiciary information.

- **System and Services Acquisition (SA):** The judiciary should: (i) allocate sufficient resources to adequately protect judiciary systems; (ii) employ system development life cycle processes that incorporate information security considerations; (iii) employ software usage and installation restrictions; and (iv) ensure that third-party providers employ adequate security measures to protect information, applications, and/or services outsourced from the judiciary.
- **System and Communications Protection (SC):** The judiciary should: (i) monitor, control, and protect judiciary communications (i.e., information transmitted or received by judiciary systems) at the external boundary and key internal boundaries of the systems; and (ii) employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within judiciary systems.
- **System and Information Integrity (SI):** The judiciary should: (i) identify, report, and correct information and system flaws in a timely manner; (ii) provide protection from malicious code at appropriate locations within judiciary systems; and (iii) monitor system security alerts and advisories and take appropriate actions in response.

Table A1 provides examples of baseline controls recommended to be implemented for a judiciary system based on its system security category as determined during Step 2 (see Figure 1 and Section 2.2).

The Security Category column identifies the recommended controls for each category: High (H), Moderate (M), or Low (L). “Yes” indicates that the control is recommended for implementation. “Opt” indicates that implementing the control would provide additional security protection (above the recommended security baseline) and is optional.

Table A1 – Sample Judiciary Recommended Security Controls

Control Name & Number	Control Description	Security Category		
		H	M	L
AC-06 Least Privilege	The organization employs the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) which are necessary to accomplish assigned tasks in accordance with organizational missions and business functions.	Yes	Yes	Yes
PE-09 Power Equipment and Cabling	The organization protects power equipment and power cabling for the information system from damage and destruction.	Yes	Yes	Opt

The complete table of Judiciary Recommended Security Controls can be found in the [JISF Guide, Appendix B](#).